Universidad Rafael Landívar
Campus San Alberto Hurtado, S.J. de Quetzaltenango
Curso: Programación Web
Docente: Ing. Manuel Rojas
Título: Eventia autenticación y control de acceso

Nombre: _____ Carné: _____

Eventia continúa creciendo. La plataforma permite publicar eventos, consultar actividades, realizar inscripciones y administrar la información de los participantes.

Durante las pruebas, el equipo de desarrollo identificó que varias funcionalidades dependen únicamente de que el usuario haya iniciado sesión. No existen políticas claras para determinar qué operaciones puede realizar cada persona.

Actualmente se presentan las siguientes situaciones:

- Un usuario registrado puede intentar acceder a funciones de organizador.
- Dos organizadores pueden consultar los identificadores de eventos ajenos.
- La aplicación oculta ciertas opciones en el frontend, pero algunos endpoints no comprueban los permisos.
- No se ha definido claramente cuándo debe finalizar una sesión.
- El equipo propone utilizar JWT, pero desconoce si es la mejor alternativa para su arquitectura.

La empresa solicita una propuesta que permita administrar identidades, proteger recursos y comprobar que los controles funcionan correctamente.

1) Selección del mecanismo de autenticación

Analicen las necesidades de Eventia y comparen las siguientes alternativas:

- Sesiones de servidor mediante cookies seguras.
- Autenticación mediante tokens JWT.
- Inicio de sesión federado mediante OpenID Connect.

Respondan:

1. ¿Qué alternativa utilizarían para la versión actual de Eventia?
2. ¿Por qué consideran que es adecuada para su arquitectura?
3. ¿Qué ventajas y limitaciones presenta?
4. ¿Cómo se mantendría la autenticación entre solicitudes?
5. ¿Cómo manejarían el cierre de sesión y la expiración de las credenciales?

No deben implementar los tres mecanismos. Seleccionen uno y justifiquen su decisión.

2) Elaboren un diagrama que represente el proceso completo:

- El usuario solicita iniciar sesión.
- El backend verifica su identidad.
- El sistema establece una sesión o entrega la credencial correspondiente.
- El usuario solicita un recurso protegido.

- El backend comprueba la autenticación.
- La aplicación permite o rechaza la solicitud.

Incluyan también qué sucede cuando la sesión o el token ha expirado.

3) Roles y permisos

Eventia tendrá cuatro tipos de usuarios:
Visitante: Persona que todavía no ha iniciado sesión.
Usuario registrado: Puede consultar eventos e inscribirse.
Organizador: Puede crear y administrar sus propios eventos.
Administrador: Puede realizar operaciones administrativas autorizadas.

Construyan una matriz de permisos considerando las siguientes operaciones:

1. Consultar eventos públicos.
2. Inscribirse en eventos.
3. Consultar inscripciones propias.
4. Crear eventos.
5. Modificar eventos propios.
6. Modificar eventos de otros organizadores.
7. Consultar participantes de eventos propios.
8. Administrar usuarios.

Para cada operación indiquen qué roles tienen acceso y qué condiciones adicionales deben cumplirse.

4) Analicen las siguientes situaciones:

Situación A: Un organizador intenta modificar un evento que pertenece a otro organizador.
Situación B: Un usuario registrado intenta consultar las inscripciones privadas de otra persona.
Situación C: Un administrador intenta realizar una operación administrativa con una sesión vencida.
Situación D: Un organizador intenta modificar un evento propio que ya fue cerrado y no admite cambios.
Para cada situación indiquen:

1. ¿Debe permitirse o rechazarse la operación?
2. ¿Qué comprobaciones debe realizar el backend?
3. ¿Qué código HTTP corresponde?
4. ¿Qué modelo de control de acceso aplicarían: RBAC, ABAC o ReBAC? Justifiquen.

5) Utilizando el proyecto Eventia desarrollado anteriormente, implementen o completen un mecanismo de autenticación según la estrategia seleccionada.

Deberán demostrar:

- Inicio de sesión de un usuario.
- Acceso a una ruta protegida.
- Rechazo de una solicitud sin autenticación válida.
- Manejo de una sesión o credencial inválida o vencida.

Si ya cuentan con autenticación implementada, deberán revisarla y demostrar que funciona correctamente.

6) Implementen al menos dos controles de autorización:

Control 1: Un organizador únicamente puede modificar eventos que le pertenecen.
Control 2: Un usuario registrado únicamente puede consultar sus propias inscripciones.

La comprobación debe realizarse en el backend. No se aceptará como solución únicamente ocultar botones o secciones del frontend. Pueden utilizar Guards, servicios y las herramientas de NestJS estudiadas en clase.

7) Realicen las siguientes pruebas utilizando Postman, Thunder Client o una herramienta equivalente:
    1. Acceder a una ruta privada sin autenticación.
    2. Acceder a una ruta privada con autenticación válida.
    3. Modificar un evento propio como organizador autorizado.
    4. Intentar modificar un evento perteneciente a otro organizador.
    5. Intentar consultar inscripciones privadas de otro usuario.
    6. Utilizar una sesión o token inválido o vencido.

Para cada prueba documenten:

- Operación realizada.
- Usuario o rol utilizado.
- Resultado esperado.
- Código HTTP obtenido.
- Resultado real.
- Captura de evidencia.

Entregables

1. Comparación y justificación del mecanismo de autenticación seleccionado.
2. Diagrama del flujo de autenticación.
3. Matriz de roles y permisos.
4. Análisis de las cuatro situaciones de control de acceso.
5. Repositorio de Eventia con los controles implementados.
6. Evidencias de las seis pruebas.